

CYBERSECURITY

LAB7c: Session Hijacking Detection

D.E. MENACER (CEH)

Copyright © ESI – 2026

INTRODUCTION

- Session hijacking is very dangerous; it places the victim at risk of identity theft, fraud, and loss of sensitive information.
- All networks that use TCP/IP are vulnerable to different types of hijacking attacks.
- Moreover, these kinds of attacks are very difficult to detect, and often go unnoticed unless the attacker causes severe damage.

INTRODUCTION

- However, following best practices can protect against session hijacking attacks.
- Fortunately, there are various tools available that can help you to detect session hijacking attacks such as packet sniffers, IDSs, and SIEMs.

SIEM

- Security information and event management (**SIEM**) solutions help organizations **detect**, **analyze**, and **respond** *to security threats before they can impact their business.*
- **SIEM** (pronounced "sim") technologies combine security information management (**SIM**) and security event management (**SEM**) into a single security management system.
- A **SIEM** system collects **event log data** from various sources, identifies abnormal activity through real-time analysis, and applies appropriate measures.

LAB: SH DETECTION WITH WIRESHARK

- **To carry out this lab, you need:**
 - Windows 11 virtual machine
 - Parrot Security virtual machine
 - Web browsers with an Internet connection
 - Administrator privileges to run the tools
- **Lab Duration : 10 Minutes 😊**

WIRESHARK

- **Wireshark** allows you to capture and interactively browse the traffic running on a network.
- The tool uses **WinPcap** to capture packets, and so is only able to capture packets on networks that are supported by WinPcap.
- It **captures live network traffic** from **Ethernet**, **IEEE 802.11**, **PPP/HDLC**, **ATM**, **Bluetooth**, **USB**, **Token Ring**, **Frame Relay**, and **FDDI** networks.
- Security professionals can use **Wireshark** to monitor and detect session hijacking attempts

TASKS TO DO

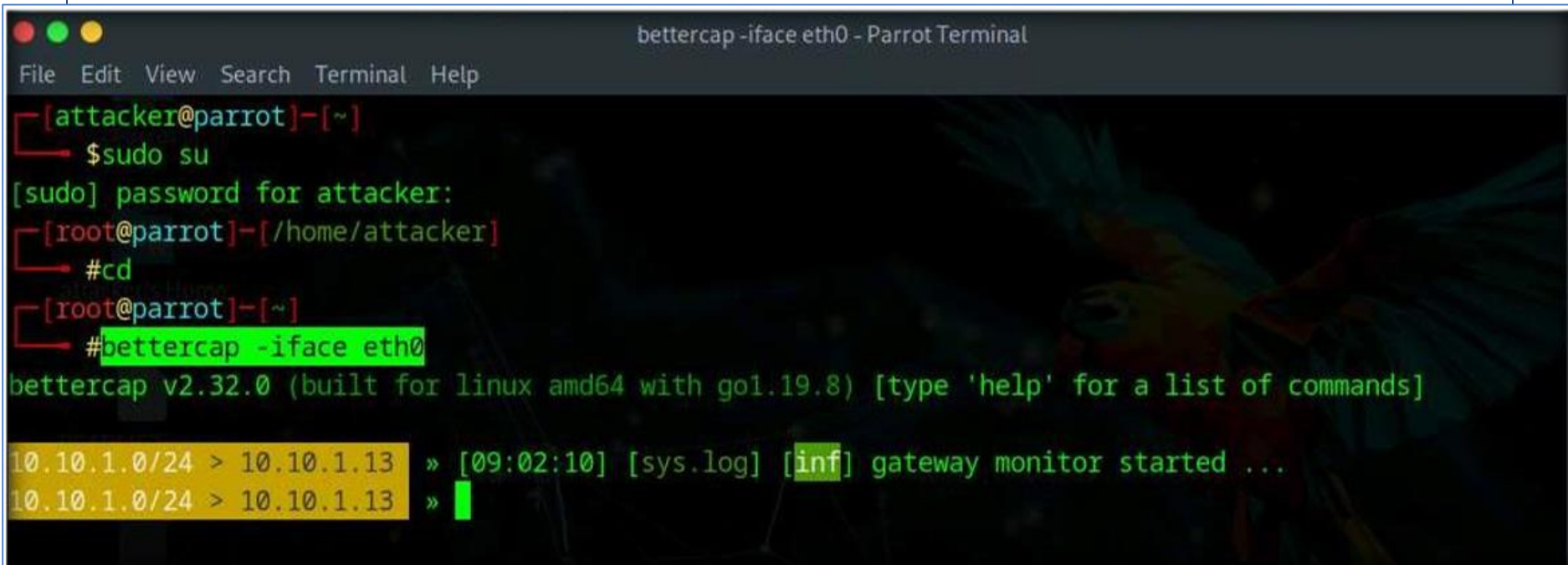
- **Note:** We will use the Parrot Security (10.10.1.13) machine to carry out a session hijacking attack on the Windows 11 (10.10.1.11) machine.
- Turn on the Windows 11 and Parrot Security virtual machines.
- Switch to the Windows 11 machine. Login using Admin/Pa\$\$w0rd.
- Click the windows Search icon on the Desktop, search for Wireshark in the search bar and launch it.
- The Wireshark Network Analyzer window appears, start capturing the network traffic on the primary network interface (here, Ethernet).

TASKS TO DO

- Now, we shall launch a **session hijacking** attack on the **target machine (Windows 11)** using **bettercap**.
 - **Note**: To do so, follow the steps below.
- Switch to the **Parrot Security** machine and login with **attacker/toor**.
- Open a **Terminal window** and execute **sudo su** to run the programs as a root user (When prompted, enter the password **toor**). Run **cd** to jump to the **root directory**.

TASKS TO DO

- Run `bettercap -iface eth0` to set the network interface.
- **Note:** `-iface`: specifies the interface to bind to (here, `eth0`).

A screenshot of a Parrot Terminal window titled "bettercap -iface eth0 - Parrot Terminal". The terminal shows a user named "attacker" at a machine named "parrot" in their home directory. They run "sudo su" to become root. The prompt changes to "[root@parrot]~". They then run "cd" and the prompt changes to "[root@parrot]~". Finally, they run "bettercap -iface eth0". The terminal output shows "bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]". Below this, there are two lines of output: "10.10.1.0/24 > 10.10.1.13 » [09:02:10] [sys.log] [inf] gateway monitor started ..." and "10.10.1.0/24 > 10.10.1.13 »". The terminal has a dark background with a faint parrot logo. The window has standard Linux window controls (red, green, yellow buttons) at the top left.

```
File Edit View Search Terminal Help

[attacker@parrot]~
$ sudo su
[sudo] password for attacker:
[root@parrot]~/home/attacker
# cd
[root@parrot]~
# bettercap -iface eth0
bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]

10.10.1.0/24 > 10.10.1.13 » [09:02:10] [sys.log] [inf] gateway monitor started ...
10.10.1.0/24 > 10.10.1.13 »
```

TASKS TO DO

- Type `net.probe on` and press Enter.
 - This module will send different types of probe packets to each IP in the current subnet for the `net.recon module` to detect them.
- Type `net.recon on` and press Enter.
 - This module is responsible for periodically reading the system ARP table to detect new hosts on the network.
- **Note:** The `net.recon` module displays the detected active IP addresses in the network. In real-time, this module will start sniffing network packets.

TASKS TO DO

- Type `net.sniff on` and press Enter.
 - This module is responsible for performing sniffing on the network.
- You can observe that `bettercap` starts sniffing network traffic on different machines in the network, as shown in the following screenshot.

TASKS TO DO

```
File Edit View Search Terminal Help
bettercap -iface eth0 - Parrot Terminal

[root@parrot]-[/home/attacker]
#cd
[root@parrot]-[~]
#bettercap -iface eth0
bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]

10.10.1.0/24 > 10.10.1.13 » [09:02:10] [sys.log] [inf] gateway monitor started ...
10.10.1.0/24 > 10.10.1.13 » net.probe on
[09:04:08] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe
10.10.1.0/24 > 10.10.1.13 » [09:04:08] [sys.log] [inf] net.probe probing 256 addresses on 10.10.1.0/
24
10.10.1.0/24 > 10.10.1.13 » [09:04:08] [endpoint.new] endpoint 10.10.1.9 detected as 02:15:5d:45:41:
2f.
10.10.1.0/24 > 10.10.1.13 » [09:04:08] [endpoint.new] endpoint 10.10.1.11 (WINDOWS11) detected as 00
:15:5d:01:80:00 (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » [09:04:09] [endpoint.new] endpoint 10.10.1.19 (SERVER2019) detected as 0
2:15:5d:45:41:2e.
10.10.1.0/24 > 10.10.1.13 » [09:04:09] [endpoint.new] endpoint 10.10.1.22 (SERVER2022) detected as 0
0:15:5d:01:80:02 (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » net.recon on
10.10.1.0/24 > 10.10.1.13 » [09:04:21] [sys.log] [err] module net.recon is already running
10.10.1.0/24 > 10.10.1.13 » net.sniff on
10.10.1.0/24 > 10.10.1.13 » [09:04:46] [net.sniff.mdns] mdns fe80::15:5dff:fe45:4130 : Android.local
is fe80::15:5dff:fe45:4130
10.10.1.0/24 > 10.10.1.13 »
```

TASKS TO DO

- Switch back to the **Windows 11** machine and observe the huge number of ARP packets captured by the **Wireshark**, as shown in the screenshot.
 - **Note:** **bettercap** sends several ARP broadcast requests to the hosts (or potentially active hosts).

TASKS TO DO

- A high number of ARP requests indicates that the system at 10.10.1.13 (the attacker's system) is acting as a client for all the IP addresses in the subnet, which means that all the packets from the victim node (10.10.1.11) will first go to the host system (10.10.1.13), and then the gateway.
- Similarly, any packet destined for the victim node is first forwarded from the gateway to the host system, and then from the host system to the victim node.

TASKS TO DO

Capturing from Ethernet						
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help						
Apply a display filter ... <Ctrl-/>						
No.	Time	Source	Destination	Protocol	Length	Info
3360	443.659266	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.172? Tell 10.10.1.13
3360	443.662624	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.74? Tell 10.10.1.13
3360	443.662659	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.76? Tell 10.10.1.13
3360	443.665750	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.75? Tell 10.10.1.13
3360	443.669357	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.173? Tell 10.10.1.13
3360	443.679878	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.174? Tell 10.10.1.13
3360	443.689116	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.79? Tell 10.10.1.13
3360	443.689136	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.77? Tell 10.10.1.13
3360	443.689157	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.78? Tell 10.10.1.13
3360	443.690431	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.175? Tell 10.10.1.13
3360	443.701047	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.176? Tell 10.10.1.13
3360	443.711444	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.177? Tell 10.10.1.13
3360	443.715597	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.80? Tell 10.10.1.13
3360	443.715607	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.81? Tell 10.10.1.13
3360	443.721650	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.178? Tell 10.10.1.13
3360	443.732229	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.179? Tell 10.10.1.13
3360	443.742351	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.82? Tell 10.10.1.13
3360	443.742376	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.83? Tell 10.10.1.13
3360	443.742487	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.84? Tell 10.10.1.13
3360	443.742915	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.180? Tell 10.10.1.13
3360	443.753101	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.181? Tell 10.10.1.13
3360	443.763652	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.182? Tell 10.10.1.13
3360	443.769080	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.86? Tell 10.10.1.13
3360	443.772378	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.85? Tell 10.10.1.13
3360	443.774189	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.183? Tell 10.10.1.13
3360	443.784214	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.184? Tell 10.10.1.13
3360	443.794809	MS-NLB-PhysServer-2	Broadcast	ARP	42	Who has 10.10.1.185? Tell 10.10.1.13
> Frame 1: 42 bytes on wire (336 bits), 42 bytes captured (336 bits) on interface 0 > Ethernet II, Src: Microsoft_01:80:02 (00:15:5d:01:80:02), Dst: Broadcast > Address Resolution Protocol (request)				0000	ff ff ff ff ff ff 00 15 5d 01 80 02 08 06 00 01	].....
				0010	08 00 06 04 00 01 00 15 5d 01 80 02 0a 0a 01 16	].....
				0020	00 00 00 00 00 00 a9 fe a9 fe	

ENDING THE LAB

- This concludes the demonstration of how to detect a session hijacking attack using Wireshark.
- Close all open windows and document all the acquired information.
- Turn off the Windows 11 and Parrot Security virtual machines.